

Authentication research notes

- Task 1 deliverable (Poorvi Bagga)

What is authentication?

Authentication is the process of verifying that an individual attempting to access a digital service actually controls the devices or credentials associated with their digital identity. To do this, authenticators such as passwords, security tokens, or biometric information must be verified. Successful authentication ensures that the service is used by the same person over time. It can be single-factor or multi-factor methods. To protect digital identities, authentication of information is an important step.

Used resources:

1. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
2. <https://pages.nist.gov/800-63-3/sp800-63b.html>

Method 1: Password-based

How does it work?

Users who log in with a password must enter credentials, such as a username and password, in order to authenticate themselves. Only if their credentials match those in the database will the system grant them access. Users choose a password that typically meets specific requirements, for example, having a character and a digit and being 7 characters long. The system safely stores it with a unique identifier. The system verifies the entered credentials against the credentials stored when a user logs in. The user is granted access if they match the criteria. If not, access is blocked, and the user may need to re-enter their information or reset their password.

Advantage?

- Since passwords are the most widely used authentication method, most users are familiar with them. This familiarity lowers support requests and allows a more seamless user experience.
- Password-based authentication is easy to use and less expensive than techniques that require additional hardware or technology. While it still offers a degree of security.
- Passwords are under the user's control and can be reset or changed at any time.

Disadvantage?

- Passwords that are weak or used across multiple systems are particularly vulnerable to theft or brute-force attacks.
- Just around one-third of users avoid reusing passwords across platforms, and many choose weak passwords.

- Passwords are frequently forgotten by users, computers containing saved credentials may crash, and hard copies of passwords may be misplaced or stolen.
- Users may find password-based authentication annoying if it requires overly complex passwords or strict guidelines.

Used resources:

<https://www.descope.com/learn/post/password-authentication>

Method 2: Multi-Factor Authentication (2FA)

How does it work?

Before accessing their accounts, multiple factors must be authenticated. This is where a user is asked to provide two different means of identification before being allowed access. This significantly enhances account security. To begin with, a user needs to provide a username and a password. Then the system demands a second identity, such as a token that a user has or is. This is typically a system of codes that requires a user to provide a one-time password, answer a question, or present a printout before being allowed access.

Advantage?

- Better security, because if your password has been compromised in some way, there is also another factor to consider.
- Aids in blocking unauthorized access by demanding what the attacker cannot possess, i.e., a phone and biological data.
- Provides a flexible system, as this second factor could also involve SMS codes, authenticators, hardware tokens, and biometrics.
- Reduces recovery, as the accounts are more difficult to breach.
- Encourages user trust by providing additional security.

Disadvantage?

- This depends on the devices used; thus, users will be locked out of their accounts if they lose their phones or tokens.
- Additionally, second factors that can be intercepted, such as those sent through an SMS code, lower security as a result.
- The login time might be longer due to this additional step.
- Technical issues, such as delayed code or app synchronization, might also hinder access.
- Not completely immune to advanced attacks if its system is not implemented securely.

Used resources:

<https://www.telkomsel.com/en/enterprise/insight/blog/pros-cons-two-factor-authentication-2fa>

Method 3: Single Sign-On (SSO)

How does it work?

This technique allows users to avoid entering additional details when accessing various applications in a system. They only need to log in once. Users require only a single username and password; a single system handles all applications, eliminating the need to re-enter the same details multiple times.

Advantage?

- Ensures cross-application work runs smoothly and effortlessly.
- Users have to remember only a few passwords to access accounts.
- Talking of centralized identity and access management, this ensures efficient management.
- Streamlining login will greatly increase productivity and improve the overall user experience.

Disadvantage?

- If there is an issue with the main SSO login, access to other connected applications will also be affected.
- Some old or specialized programs may have complex integration in demand.

Used resources:

<https://trueconf.com/blog/wiki/sso-single-sign-on>

Method 4: Token-Based Authentication (JWT / OAuth2)

How does it work?

In the system's authentication feature, we use JSON Web Tokens and OAuth2 tokens. After the client enters credentials to the server for the login operation, the server evaluates the JSON Web Token by validating its signature and verifying its contents before the client uses the token to access the API's resources. JSON Web Tokens are self-contained and thus don't consume much server memory; therefore, their use simplifies the client's validation of API resources. On the other hand, the use of OAuth2 tokens ensures the system's smooth operation by enabling it to work with different platforms.

Advantage?

- They are self-contained messages that do not require additional server-side storage, thereby enhancing scalability.

- All important information may be encoded in the token. Thus, database queries may not always be required
- JWTs work well in modern stateless architectures.
- JWTs are good across domains; this is good in many mobile applications
- JWTs can be signed and even encrypted. This ensures security.
- Security controls that OAuth2 has, like token expiration or revocation, also help alleviate breaches
- OAuth 2.0 is a widely adopted industry-standard protocol that enables easy integration with other services.

Disadvantage?

- It is not easy to invalidate JWTs before their expiry date. JWTs cannot be revoked before the expiry date
- Improper handling of JWTs leads to security vulnerabilities that demand secure storage
- The information in JWT includes all the information in the token, and can also be large in size
- OAuth2 configuration is known to be quite challenging. In the OAuth2 model for user authentication, complexity can increase as the number of components increases.
- Managing OAuth2 access and refresh tokens can be complex, requiring careful planning and ongoing monitoring.

Used resources:

<https://www.akto.io/blog/oauth-vs-jwt>

Method 5: Biometric Authentication

How does it work?

The process of authenticating in applications using biometric technologies involves sensors in your device, for instance, fingerprint or face ID sensors, which check your identity through biometric verification technologies integrated in your device. When you try to access an application, it will check your system to verify your identity. It will only tell you whether it has matched, but it will not reveal your biometric details to hackers.

Advantage?

- Enhanced security, as it is not easily guessable or shareable like passwords
- Easy, fast, and convenient login, as one can unlock their app quickly
- Better user experiences due to the smooth and secure experiences of modern applications

- Fewer hassles with support, as there are no requests for password resetting or account recovery

Disadvantage?

- Concerns related to privacy: Given the personal nature of the data collected in this, i.e., a warranted entrant can be refused entry.
- Performance will depend upon the device, so less efficient hardware may cause problems
- Biometric information is irreversible, like any password.

Used resources:

<https://medium.com/@lathusanlathusan40/biometric-authentication-on-android-secure-and-user-friendly-access-control-9f17e20eed24>